Audit de securite - Plateforme Code un max

Casser des empreintes de mots de passe avec John the Ripper et Hashcat

1. Installation des outils

- John the Ripper : Un outil historique et polyvalent de cassage de mots de passe qui s'exécute principalement sur processeur (CPU) et excelle dans les attaques par dictionnaire ou par force brute.
- Hashcat : Le casseur de mots de passe le plus rapide au monde, optimisé pour utiliser la puissance des cartes graphiques (GPU) afin de craquer massivement et à très grande vitesse des empreintes numériques (hashs).
- OpenSSL : Une boîte à outils cryptographique fondamentale utilisée pour sécuriser les communications sur le web (génération de clés, certificats SSL/TLS, chiffrement et déchiffrement de fichiers).

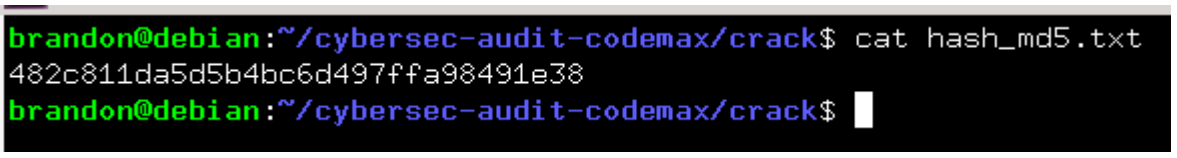
```
docker exec attaquant bash -c "apt-get update && apt-get install -y john
hashcat openssl
```

1.2 Création d'un dossier de travail dans le montage partagé

```
docker exec attaquant mkdir -p /data/crack
```

2. Génération d'une empreinte MD5 non salée d'un mot de passe faible

```
docker exec attaquant bash -c "echo -n password123 | md5sum | cut -d ' ' -
f1 > /data/crack/hash_md5.txt"
```



3. Constitution d'une liste de mots de passe

```
docker exec attaquant bash -c "printf
'azerty\n123456\npassword123\nmotdepasse\n' > /data/crack/dico.txt"
```

```
brandon@debian:~/cybersec-audit-codemax/crack$ cat dico.txt
azerty
123456
password123
motdepasse
brandon@debian:~/cybersec-audit-codemax/crack$
```

4. Lancer une attaque par dictionnaire

```
docker exec attaquant hashcat -m 0 -a 0 /data/crack/hash_md5.txt
/data/crack/dico.txt --force
```

```
brandon@debian:~/cybersec-audit-codemax/crack$ docker exec attaquant hashcat -m 0 -a 0 /data/crack/hash_md5.txt /data/crack/
dico.txt --potfile-disable --force
hashcat (v6.2.6) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 PoCL 3.1+debian  Linux, None+Asserts, RELOC, SPIR, LLVM 15.0.6, SLEEF, DISTRO, POCL_DEBUG) - Platform
 #1 [The pocl project]
================================================================================================================================
=====================
* Device #1: pthread-haswell-Intel(R) Core(TM) i5-14600K, 2914/5892 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Counting lines in /data/crack/hash_md5.txt. Please be patient...Counted lines in /data/crack/hash_md5.txtParsed Hashes: 1/1
(100.00%)Parsed Hashes: 1/1 (100.00%)Sorting hashes. Please be patient...Sorted hashesRemoving duplicate hashes. Please be p
atient...Removed duplicate hashesSorting salts. Please be patient...Sorted saltsGenerating bitmap tables...Generated bitmap
tablesHashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Hash
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
```

4.1 Affiché le résultat trouvé

```
docker exec attaquant hashcat -m 0 /data/crack/hash_md5.txt --show
```

```
brandon@debian:~/cybersec-audit-codemax/crack$ docker exec attaquant hashcat -m 0 /data/crack/hash_md5.txt --show
482c811da5d5b4bc6d497ffa98491e38:password123
brandon@debian:~/cybersec-audit-codemax/crack$
```

5. Génération d'une empreinte bcrypt salée du même mot de passe

```
docker exec attaquant bash -c "openssl passwd -6 -salt N1aqXz7p password123
> /data/crack/hash_sha512.txt"
```

```
brandon@debian:~/cybersec-audit-codemax/crack$ cat hash_sha512.txt
$6$N1aqXz7p$SqNF2Nw/EvntQboooGhOycUTx8JtBdc/y.HJj2mrB2V7y3iNWQ/XNwHB4crqs.tLf417nB8/rdQv2s940T.a60
brandon@debian:~/cybersec-audit-codemax/crack$
```

5.1 Cassage du mot de passe avec John The Ripper

```
docker exec attaquant john --wordlist=/data/crack/dico.txt
/data/crack/hash_sha512.txt
```

5.2 Affichage du résultat

```
docker exec attaquant john --show /data/crack/hash_sha512.txt
```

```
brandon@debian:~/cybersec-audit-codemax/crack$ docker exec attaquant john --show /data/crack/hash_sha512.txt
?:password123

1 password hash cracked, 0 left
```

6. Conclusion

6.1 Constat de l'audit

- **Stockage vulnérable** : L'utilisation d'algorithmes rapides non salés (ex: MD5) permettent un cassage pratiquement instantané par dictionnaire ou tables arc-en-ciel.
    - Une **table arc-en-ciel** est une base de données précalculer utlisée en cryptanalyse pour retrouver des mots de passes en clair à partir de leurs empreintes numériques.
- **Politique de mots de passe** : L'exposition de mots de passe faibles et courants (ex: `password123`, `azerty`). La wordlist la plus célèbre et la plus utilisée et la wordlist `rockyou.txt` du même nom que de l'entreprise qui a subit une cyberattaque en décembre 2009.

6.2 Contre-mesures et recommandations

- **Hachage robuste et lent** : Remplacer des algorithmes rapides comme MD5 par des algorithmes de hache lents comme `bcrypt`. Ils intègrent un "sel" qui est une donnée aléatoire unique ajoutée au mot de passe et demande un effort de calcul volontairement élevé au serveur. Cela permet de rendre le cassage très coûteux en temps pour un attaquant. Le but est de ralentir voir dissuader l'attaquant.
- **Politique de mot de passe stricte** : Imposer une longueur minimal stricte (par exemple 16 caractères). A savoir qu'une phrase longue peut être beaucoup mieux qu'un mot de passe avec des mininuscules, majuscules, chiffres et caractères spéciaux.
- **Limitation des requêtes (Rate limiting)** : Consiste à bloquer ou ralentir les adresses IP qui tentent un trop grond nombre de connexions en peu de temps pour empêcher les attaques automatisées.
- **Vérouillage de compte** : Suspendre temporairement un compte après un nombre limité de tentatives par exemple blocage après 5 échecs.
- **MFA** : Aujourd'hui, il faut activer l'authentification multifacteur (SMS, application d'authentification) pour éviter qu'un mot de passe volé ne suffise plus à compromettre un compte.